

U.S. DEPARTMENT OF AGRICULTURE
WASHINGTON, D.C. 20250

DEPARTMENTAL REGULATION	NUMBER: DR 3540-005
SUBJECT: Cybersecurity Risk Management Framework	DATE: June 23, 2026
OPI: Office of the Chief Information Officer, Cybersecurity and Privacy Operations Center	EXPIRATION DATE: June 23, 2031

<u>Section</u>	<u>Page</u>
1. Purpose	1
2. Scope	1
3. Special Instructions/Cancellations	2
4. Background	3
5. Policy	3
6. Roles and Responsibilities	5
7. Penalties and Disciplinary Actions for Noncompliance	13
8. Policy Exceptions	14
9. Inquiries	14
Appendix A – Acronyms and Abbreviations	A-1
Appendix B – Definitions	B-1
Appendix C – Authorities and References	C-1

1. PURPOSE

This Departmental Regulation (DR) sets the United States Department of Agriculture (USDA) policy for a Cybersecurity risk management framework (RMF).

2. SCOPE

a. This policy applies to all:

- (1) Mission Areas, agencies, staff offices, and USDA personnel who work for or on behalf of USDA. The term “USDA personnel” encompasses USDA employees, appointees, contractors, partners, interns, fellows, affiliates, and volunteers;

- (2) Federal data in any medium or form the USDA, or those working on behalf of the USDA, generates, collects, provides, transmits, stores, maintains, or accesses;
 - (3) Systems or services, including cloud-based, that the USDA or those on behalf of the USDA use or operate. These include connections between or among data systems or services; and
 - (4) Facilities from which these systems operate, whether the USDA or another entity on behalf of the USDA uses or operates them.
- b. Nothing in this policy alters the need to protect national security systems or data.

3. SPECIAL INSTRUCTIONS/CANCELLATIONS

- a. This DR takes effect immediately when published. It remains in effect until superseded or expiration.
- b. All USDA Mission Areas, agencies, and staff offices will align their RMF plans within 6 months of its publication.
- c. This policy supersedes in their entirety:
 - (1) Departmental Manual 3575-001, *Security Controls in the System Life Cycle / Systems Development Life Cycle*, May 27, 2005;
 - (2) Departmental Notice 3420-001, *Implementation of Requirements in Authoritative References*, April 12, 2022;
 - (3) DR 3140-001, *USDA Information Systems Security Policy*, May 15, 1996;
 - (4) DR 3540-003, *Security Assessment and Authorization*, August 12, 2014; and
 - (5) DR 3565-003, *Plan of Action and Milestones Policy*, September 25, 2013.
- d. This DR complies with:
 - (1) The [Committee on National Security Systems](#) policies, directives, and instructions;
 - (2) [Executive Order \(E.O.\) 13800](#), *Strengthening the Cybersecurity of Federal Networks and Critical Infrastructure*;
 - (3) The *Federal Information Security Modernization Act of 2014*, [44 United States Code \(U.S.C.\) § 3551, et seq.](#);
 - (4) Federal requirements to set, enact, and enforce risk management;

- (5) Intelligence community policies, directives, and instructions;
- (6) National Institute of Standards and Technology (NIST) [Federal Information Processing Standards Publication \(FIPS PUB\) 200](#), *Minimum Security Requirements for Federal Information and Information Systems*;
- (7) NIST [Special Publication \(SP\) 800-37](#), Revision 2, *Risk Management Framework for Information Systems and Organizations*;
- (8) NIST [SP 800-53](#), Revision 5, *Security and Privacy Controls for Information Systems and Organizations*; and
- (9) Office of Management and Budget (OMB) [M-24-15](#), *Modernizing the Federal Risk and Authorization Management Program (FedRAMP)*.

4. BACKGROUND

FISMA directs all Federal agencies to protect Federal data and systems. Agencies must adopt actions to offset potential risk and harm from unauthorized access, use, disclosure, disruption, modification, or destruction. The USDA cybersecurity program aligns with [NIST Cybersecurity Framework](#) (CSF) including its CSF Core, Profiles, and Tiers, and [NIST Risk Management Framework](#). USDA will use the NIST RMF 7-step process.

5. POLICY

- a. The USDA will use its Departmental RMF, managed by the Office of the Chief Information Officer (OCIO) Cybersecurity and Privacy Operations Center (CPOC) to manage cybersecurity risk.
- b. Each Mission Area, agency, and staff office will develop, document, and enact an RMF plan within 6 months of this directive's effective date. RMF plans will:
 - (1) Have clear definitions;
 - (2) Document the authorization boundary for internet-connected devices, operational technology, and industrial control systems;
 - (3) Define the roles and responsibilities for key stakeholders overseeing operations and maintenance of assigned data systems;
 - (4) Document the operational context and environment;
 - (5) Document all data system exchanges;

- (6) Align with [DR 3185-001](#), *Enterprise Architecture*;
 - (7) Include written enactment statements describing how required technical, operational, and management security controls and associated security components are implemented. Write the enactment statements:
 - (a) In plain language that details how someone can meet security and privacy requirements; and
 - (b) In NIST-recommended, vendor-independent, machine-readable format and schemas;
 - (8) Include a categorization for data the system processes, including tags to link the data; and
 - (9) Contain all data system assessment documentation. This includes the system security plan (SSP) and privacy plan. It also includes enactment statements via the agency governance, risk, and compliance (GRC) tool.
- c. USDA will track and remediate identified cybersecurity weaknesses through the plan of action and milestone (POA&M) process. USDA will manage POA&Ms and risk-based decisions (RBDs) in accordance with the [POA&M and RBD](#) standard operating procedure (SOP).
 - d. USDA will ensure that FedRAMP-authorized cloud service offerings maintain continuous monitoring and vulnerability management activities consistent with FedRAMP ongoing authorization requirements.
 - e. OCIO will provide security and privacy common controls to Mission Areas, agencies, and staff offices.
 - f. Mission Areas, agencies, and staff offices will maintain all assessment and authorization (A&A) documentation in the GRC tool.
 - g. USDA will ensure that required FedRAMP authorization artifacts, including SSPs and assessments, comply with applicable FedRAMP requirements. USDA entities can share and build off other USDA entity's approved documents. USDA entities will follow OMB M-24-15 to reuse another entity's approved documents.
 - h. Departmental GRC and system inventory tools will produce, transmit, and ingest machine readable FedRAMP-related documents. The tools will use open security controls assessment language or any succeeding formats FedRAMP identified.

- i. USDA will send a copy of the authorization letter and any FedRAMP-related documents to the FedRAMP Program Management Office using machine readable formats. Submissions will follow FedRAMP guidance.
- j. Report the costs related to issuing FedRAMP authorizations, following OMB budget guidance.
- k. Relevant contracts will include General Services Administration language incorporating the FedRAMP security authorization requirements.
- l. Mission Areas, agencies, and staff offices will create lessons learned from their programs, control activities, procedures, and tasks. They will document and analyze these documents annually, or as needed on a continuous basis. They will use this qualitative and quantitative data to gauge effectiveness and guide process improvement.

6. ROLES AND RESPONSIBILITIES

- a. The Secretary or designee will ensure that RMF includes calculations for the potential magnitude of harm. Harm occurs when USDA's data or systems suffer unauthorized access, use, disclosure, disruption, modification, or destruction of data or systems.
- b. The Chief Information Officer (CIO) will:
 - (1) Establish and oversee implementation of the Departmental cybersecurity risk management strategy;
 - (2) Oversee information technology (IT)-related annual and multiyear plan, program, and budget activities;
 - (3) Oversee IT-related management, governance, and oversight processes;
 - (4) Take on the role of Senior Agency Official for Privacy (SAOP). As SAOP, oversee the conduct of privacy assessments and effective enactment of privacy controls during system authorizations;
 - (5) Adequately fund all components of the Departmental cybersecurity program;
 - (6) Develop, issue, and maintain an enterprise architecture. Ensure that it considers data security and collective risk across the enterprise. Apply guidance from NIST, OMB, and the Federal CIO Council;
 - (7) Assist with USDA direction and guidance for security and privacy common controls. This includes other risk management strategies, programs, and governance bodies related to department risk, as applicable; and

- (8) Submit an annual report on the efficacy of deployed controls in privacy and security programs to all oversight bodies, as required. This includes the Office of Inspector General (OIG), the Department of Homeland Security, OMB, and Congress.
- c. The Director of the Office of Budget & Program Analysis, serving as the Chief Risk Officer and Senior Accountable Official for Risk Management, will:
 - (1) Provide oversight of enterprise cybersecurity risk management and reporting; and
 - (2) Collaborate with the CIO to ensure cybersecurity risks are integrated into enterprise risk management processes.
- d. The Chief Information Security Officer (CISO) will:
 - (1) Incorporate RMF into the USDA cybersecurity program;
 - (2) Direct the cybersecurity program. Oversee the deployment of funds and resources for cybersecurity risk management across the enterprise;
 - (3) Manage enterprise risk proportional to potential harm;
 - (4) Perform other control-specific functions assigned in directives related to this DR;
 - (5) Ensure compliance with all Federal guidance; and
 - (6) Along with the SAOP, oversee USDA's direction and guidance on risk-related privacy common controls in other risk management strategies, programs, and governance bodies.
- e. OCIO Center Associate CIOs will:
 - (1) Oversee the budget and business operations for systems and services; and
 - (2) Serve as authorizing official (AO) for their OCIO Centers. As the AO:
 - (a) Bear sole responsibility for accepting system risk. Bear sole responsibility for granting authorization to operate (ATO) requests for designated time periods;
 - (b) Approve, review, and update all relevant data system authorization documents. This will occur annually or after a significant change;
 - (c) Determine whether major changes in data systems or operational environments impel reauthorization;
 - (d) Enact a quality control process for reviewing security control assessment plans. The process can work on a risk-based rotation or as-needed basis. Such

reviews will ensure that test plans incorporate required controls for each application's baseline;

- (e) If the AO changes, the new AO must review the risk documentation for each system under their purview. The new AO will then issue an updated authorization memorandum to cover the current ATO's duration; and

- (f) Maintain and update relevant documentation in USDA's GRC tool.

f. The USDA Inspector General will:

- (1) Evaluate the USDA data security program annually. Do this by testing the efficacy of data security policies, procedures, and practices. Use a representative subset of USDA's systems and services to perform the test; and
- (2) Coordinate with the CIO, the CISO, and other USDA officials, as appropriate, on matters of data security.

g. The Director of the Office of Homeland Security will:

- (1) Oversee and manage physical security risks; and
- (2) Coordinate with the USDA CIO and CISO on physical cybersecurity risk management.

h. The Chief Human Capital Officer of the Office of Human Resources Management will:

- (1) Assist and advise agencies on data security position designations; and
- (2) Define appropriate sanctions for personnel who violate data security policies.

i. The Chief Privacy Officer will:

- (1) In coordination with the CISO, oversee development, approval, enactment, maintenance, and management of privacy policies, program plans, and procedures;
- (2) Select and enact privacy common controls and hybrid controls. Document them in the GRC tool;
- (3) Ensure that privacy common controls and hybrid controls undergo annual evaluations;
- (4) Oversee and direct the privacy program set up of continuous monitoring. The purpose of continuous monitoring is to assess privacy controls, maintain ongoing awareness, and manage privacy risks;

- (5) Coordinate with the CISO, the Cyber Defense Operations Division (CDOD) Director, and Mission Area Assistant CIOs and CISOs during privacy-related incidents;
 - (6) Advise the SAOP on privacy matters. Report on the efficacy of privacy controls deployed in USDA systems; and
 - (7) In coordination with the CISO, oversee USDA's direction and guidance on risk-related privacy common controls in other risk management strategies, programs, and governance bodies.
- j. Mission Area Assistant CIOs will:
- (1) Advise the CIO and CISO on any issues of potential public concern, infrastructure protection, or flaws;
 - (2) Establish the data security program and the associated operational data resources plan under their purview;
 - (3) Make sure IT security risk evaluation, documentation, enactment, and management transpire in their purview;
 - (4) Ensure sufficient funding for mitigations;
 - (5) Ensure compliance with all Federal and Departmental requirements;
 - (6) Review and update documentation at least annually;
 - (7) Designate RMF responsibilities. Ensure accountability for roles within their Mission Area, including any deputies or alternates, or those acting in those roles;
 - (8) Ensure that Mission Area RMF roles meet requisite professional qualifications and appropriate security clearance levels;
 - (9) Serve as AO for their Mission Area. The AO cannot delegate formal acceptance of risks, approval of waiver requests, or ATO issuance;
 - (10) Confer with another AO for joint approval of high value assets that require two AOs;
 - (11) Define and address data security impact, requirements, and concerns during IT gate reviews;
 - (12) Ensure that each system's documentation passes through a review, validation, and approval. Provide the documentation in reports, as required;

- (13) Develop and maintain a security architecture aligned with the USDA enterprise architecture. Base it on current risk assessments and security requirements; and
- (14) Oversee the budget and business operations for systems and services in their purview.

k. Mission Area Assistant CISOs will:

- (1) Along with the CISO, enact, manage, measure, and oversee all components of the USDA cybersecurity program at the Mission Area level;
- (2) Serve as the principal information security specialist and consultant to all personnel and users within their purview;
- (3) Support configuration management in alignment with enterprise architecture;
- (4) Develop, enact, annually review, and update the tailored Mission Area information security program plan and procedures;
- (5) Use the GRC tool to manage and measure the tailored Mission Area information security program efficacy;
- (6) Manage the applicable security controls for each Mission Area system;
- (7) Formally designate a System Owner and an Information System Security Manager (ISSM) for each system annotating the function in the agency systems;
- (8) Ensure that their critical infrastructure's security and contingency plans incorporate data security;
- (9) Ensure that USDA internal and external systems and services use the same data security and risk management standards;
- (10) Conduct a full assessment of enacted controls and control enhancements to determine effectiveness;
- (11) Provide input to RMF activities and related documentation. These include system life cycle support plans, operational procedures, and maintenance training materials;
- (12) Participate in the risk governance process to provide security risks, mitigations, and input on other technical risks;
- (13) Prepare reports for security and privacy assessment findings;
- (14) Submit required compliance reports to USDA senior officials, and OIG, OMB, Government Accountability Office, and other oversight bodies upon request; and

- (15) Ensure that all personnel in the Mission Area take annual information security awareness training. Ensure that they also take, when appropriate, role-based training.
- l. AO Designated Representatives will:
 - (1) Assist the AO with direction and guidance on security and privacy common controls pertinent to Departmental risk;
 - (2) Coordinate routine activities associated with RMF and A&A processes to protect systems and services;
 - (3) Review risk-based decision requests and recommend approval or disapproval to the AO; and
 - (4) Review SSPs and recommend approval or disapproval to the AO.
- m. Mission Area Privacy Officers will:
 - (1) Serve as the CPO's main point of contact to enact the USDA Privacy Office's policies and directives;
 - (2) Prepare privacy compliance documentation as directed by the USDA Privacy Office policy or required by law;
 - (3) Identify privacy issues related to Mission Area programs. Apply appropriate privacy policies and federal privacy laws to the relative programs;
 - (4) Monitor the Mission Area's compliance with all applicable federal privacy laws and regulations; and
 - (5) Enact and manage the privacy incident management process for your Mission Area.
- n. The OCIO CPOC, Security Management Division (SMD) will:
 - (1) Serve as the USDA FedRAMP Program Management Office;
 - (2) Regularly review continuous monitoring materials that cloud service providers submit. Provide timely and actionable feedback as necessary to manage risk to USDA; and
 - (3) Along with the CISO, enact, manage, and oversee the RMF activities, processes, practices, and tasks defined in enterprise policies.
- o. The CPOC Cybersecurity Policy & Strategy Program will:

- (1) Support oversight of the agency's procedural alignment with enterprise security and privacy policies;
 - (2) Oversee development of the USDA cybersecurity risk management strategy to enact RMF-supporting control activities, procedures, and tasks; and
 - (3) Update policies and strategies to support cybersecurity program fulfillment.
- p. The Director of CDOD will:
- (1) Respond appropriately to incidents and data breaches, coordinating with senior officials as needed; and
 - (2) Assist with maintaining a USDA risk posture aligned with requirements.
- q. The OCIO, CPOC Cybersecurity Infrastructure Division will assist with system, network, and infrastructure security maintenance.
- r. Enterprise Architects will:
- (1) Enact an architecture strategy that enables effective security and privacy solutions;
 - (2) Assist with integration of the USDA risk management strategy with system-level security and privacy requirements. Ensure alignment with program planning and budgeting activities, the system development life cycle (SDLC), acquisition processes, and systems engineering processes;
 - (3) Coordinate with Mission Area security and privacy architects to determine optimal system or component placement in the enterprise architecture. Address security and privacy issues between systems and enterprise architecture;
 - (4) Assist with decisions on appropriate control applications and initial configuration baselines as they relate to the enterprise architecture; and
 - (5) In coordination with System Owners and AOs, facilitate authorization boundary decisions and controls allocation to system elements.
- s. Common Control Providers will:
- (1) Enact, assess, and monitor common controls from a holistic organization perspective;
 - (2) Document organization-defined common controls in security and privacy plans (or equivalent documents that the USDA prescribes);

- (3) Employ independent assessors to conduct control assessments; and
- (4) Document assessment findings in control assessment reports.
- t. ISSMs will:
 - (1) Set rules for data's acceptable use, creation, storage, processing, sharing, and protection within their purview;
 - (2) Carry out assigned RMF-related data security planning, management, and operational responsibilities;
 - (3) Coordinate with System Owners to set roles, privileges, access levels, and required controls. This work will protect the system's generated, used, stored, transmitted, or otherwise processed data; and
 - (4) Coordinate with and offer guidance to agency personnel on managing the life cycle activities and data security.
- u. System Owners will:
 - (1) Manage and coordinate SDLC activities for the assigned USDA system using principles of criticality and sensitivity;
 - (2) Coordinate with system stakeholders to furnish RMF activities;
 - (3) Manage and coordinate RMF control processes, practices, and tasks when deploying security and privacy controls documented in an SSP;
 - (4) Update SSPs to address:
 - (a) System changes;
 - (b) The operational environment;
 - (c) Possible application problems; or
 - (d) Control assessment issues;
 - (5) Review SSPs annually. Distribute copies of SSPs. Communicate SSP updates to pertinent stakeholders;
 - (6) Protect SSPs with a moderate risk rating from unauthorized disclosure or modification;

- (7) Clearly define their authorization boundary in SSPs and other applicable security documentation;
- (8) Prepare authorization packages for annual AO review and for reauthorization of a system every 3 years;
- (9) Define the roles and responsibilities of key stakeholders tasked with data systems operation and maintenance;
- (10) Document each system's operational context, environment, and data exchanges;
- (11) Align with DR 3185-001;
- (12) Include a data categorization that the system processes. Select appropriate tags to link the data;
- (13) Develop written enactment statements. Include requisite technical, operational, and management security controls. Include associated security components. Write the enactment statements:
 - (a) In plain language that details how someone can meet security requirements; and
 - (b) In NIST-recommended, vendor-independent, machine-readable format and schemas;
- (14) Document and analyze qualitative and quantitative data derived from lessons learned after deploying controls and assessments;
- (15) Store and access all documentation related to the data system assessment via the agency's GRC tool;
- (16) Manage POA&Ms and coordinate remediation activities in accordance with the POA&M and RBD SOP;
- (17) Manage the development, documentation, and dissemination of maintenance procedures;
- (18) Schedule, document, and review records of maintenance, repair, and replacement on system components. Ensure that these align with manufacturer or vendor specifications and organizational requirements;
- (19) Approve and monitor all maintenance activities. Do this whether these happen on-site or remotely. Do this whether the system or system components receive service on-site or off-site;

(20) Approve, control, and monitor the use of system maintenance tools; and

(21) Review previously approved system maintenance tools.

v. Information System Security Officers will:

(1) Support the System Owner in all security functions assigned in this DR. Make sure RMF and system life cycle activities, processes, practices and tasks undergo proper enactment; and

(2) Support the System Owner in other duties assigned under other USDA directives and Federal guidance.

7. PENALTIES AND DISCIPLINARY ACTIONS FOR NONCOMPLIANCE

a. [DR 4070-735-001](#), *Employee Responsibilities and Conduct*, Section 16, *Computers*, sets forth policies, procedures, and standards on employee responsibilities and conduct as regards using computers and telecommunication equipment. In addition, DR 4070-735-001, Section 21, *Disciplinary or Adverse Action*, states:

(1) Any violation of the responsibilities or standards contained in this DR may be cause for disciplinary or adverse action; and

(2) Any disciplinary or adverse action taken will be consistent with the applicable laws and regulations.

b. Such disciplinary actions will follow applicable laws and regulations. These include those from the Office of Personnel Management, OMB, and [5 Code of Federal Regulations § 2635](#), *Standards of Ethical Conduct for Employees of the Executive Branch*.

8. POLICY EXCEPTIONS

All Mission Areas, agencies, and staff offices will conform to this policy. Any Mission Area, agency, or staff office that cannot meet a specific policy requirement must request a policy exception. To do so, email the OCIO CPOC, SMD, Risk Management Branch at POAMProgram@usda.gov. Note that an approved risk-based decision is an acceptance of risk but does not equal compliance.

9. INQUIRIES

Send any questions or concerns about this DR to the OCIO, CPOC, via CPOC-CyberPolicy@usda.gov.

-END-

APPENDIX A

ACRONYMS AND ABBREVIATIONS

A&A	Assessment and Authorization
AO	Authorizing Official
ATO	Authorization to Operate
CDOD	Cyber Defense Operations Division
CIO	Chief Information Officer
CISO	Chief Information Security Officer
CPOC	Cybersecurity and Privacy Operations Center
CSF	Cyber Security Framework
DR	Departmental Regulation
E.O.	Executive Order
FedRAMP	Federal Risk and Authorization Management Program
FIPS PUB	Federal Information Processing Standards Publication
FISMA	Federal Information Security Modernization Act of 2014
GRC	Governance, Risk, and Compliance
ISSM	Information System Security Manager
IT	Information Technology
NIST	National Institute of Standards and Technology
NISTIR	National Institute of Standards and Technology Interagency Report
OCIO	Office of the Chief Information Officer
OIG	Office of Inspector General
OMB	Office of Management and Budget
RMF	Risk Management Framework
SAOP	Senior Agency Official for Privacy
SDLC	System Development Life Cycle
SMD	Security Management Division
SOP	Standard Operating Procedure
SP	Special Publication
SSP	System Security Plan
U.S.C.	United States Code
USDA	United States Department of Agriculture

APPENDIX B

DEFINITIONS

Common Control Provider. An official responsible for the development, implementation, assessment, and monitoring of common controls. Common controls can include, e.g., security controls inherited by information systems. (Source: NIST SP 800-37, Revision 2)

Common Controls. A security control inherited by one or more organizational information systems. (Source: NIST SP 800-37, Revision 2)

Continuous Monitoring. Maintaining ongoing awareness of information security, vulnerabilities, and threats. This supports organizational risk management decisions. (Source: NIST SP 800-137)

Criticality. An attribute of an asset that reflects its relative importance or necessity in achieving, or allowing the achievement of, stated goals. (Source: NIST [SP 800-160, Volume 2](#), Revision 1, *Developing Cyber-Resilient Systems: A Systems Security Engineering Approach*)

Cyber Security Core. A taxonomy of high-level cybersecurity outcomes that can help any organization manage its cybersecurity risks. Its components are a hierarchy of Functions, Categories, and Subcategories that detail each outcome. (Source: NIST CSF 2.0)

Cyber Security Profile. A mechanism for describing an organization's current and/or target cybersecurity posture in terms of the CSF Core's outcomes. (Source: NIST CSF 2.0)

Cyber Security Tier. A characterization of the rigor of an organization's cybersecurity risk governance and management practices. There are four Tiers: Partial (Tier 1), Risk Informed (Tier 2), Repeatable (Tier 3), and Adaptive (Tier 4). (Source: NIST CSF 2.0)

Risk. The level of impact on agency operations, agency assets, or individuals resulting from operating an information system, given the potential impact of a threat and its likelihood. Agency operations can include mission, functions, image, or reputation. (Source: NIST [SP 800-30](#), Revision 1, *Guide for Conducting Risk Assessments*)

Risk Assessment. The process of identifying risks to agency operations, agency assets, or individuals. This is done by determining the probability of occurrence, the resulting impact, and additional security controls that would mitigate the impact. Agency operations can include mission, functions, image, or reputation. Risk assessment is part of risk management. It incorporates threat and vulnerability analyses. It is synonymous with risk analysis. (Source: NIST [SP 800-18](#), Revision 1, *Guide for Developing Security Plans for Federal Information Systems*)

Security Controls. The management, operational, and technical controls (i.e., safeguards or countermeasures) prescribed for a system. Their purpose is to protect the confidentiality,

integrity, and availability of the system and its components, processes, and data. (Source: NIST SP 800-82, Revision 3)

Sensitivity. The degree to which an IT system or application requires protection to ensure confidentiality, integrity, and availability. This is determined by evaluating the nature and criticality of the data processed, the relation of the system to the organization's missions, and the economic value of the system components. (Source: NIST [SP 800-16, Volume 1](#), Revision 1, *Information Technology Security Training Requirements: A Role- and Performance-Based Model*)

APPENDIX C

AUTHORITIES AND REFERENCES

[E.O. 13800](#), *Strengthening the Cybersecurity of Federal Networks and Critical Infrastructure*, May 11, 2017

[E.O. 14028](#), *Executive Order on Improving the Nation's Cybersecurity*, May 12, 2021

[E.O. 14144](#), *Strengthening and Promoting Innovation in the Nation's Cybersecurity*, January 16, 2025

[E.O. 14306](#), *Sustaining Select Efforts To Strengthen the Nation's Cybersecurity and Amending Executive Order 13694 and Executive Order 14144*, June 6, 2025

FISMA, [44 U.S.C. §§ 3551-3559](#)

NIST, [FIPS PUB 199](#), *Standards for Security Categorization of Federal Information and Information Systems*, February 2004, as amended

NIST, [FIPS PUB 200](#), *Minimum Security Requirements for Federal Information and Information Systems*, March 9, 2006, as amended

NIST, [NIST Cybersecurity Framework](#), website

NIST, [NISTIR 7693](#), *Specification for Asset Identification 1.1*, June 2011

NIST, [NIST Risk Management Framework](#), November 30, 2016, updated December 13, 2023, website

NIST, [SP 800-12](#), Revision 1, *An Introduction to Information Security*, June 2017

NIST, [SP 800-16, Volume 1](#), Revision 1, *Information Technology Security Training Requirements: A Role- and Performance-Based Model*, April 1998

NIST, [SP 800-18](#), Revision 1, *Guide for Developing Security Plans for Federal Information Systems*, February 2006, as amended

NIST, [SP 800-30](#), Revision 1, *Guide for Conducting Risk Assessments*, September 2012, as amended

NIST, [SP 800-34](#), Revision 1, *Contingency Planning Guide for Federal Information Systems*, May 2010, as amended

[E.O. 13800](#), *Strengthening the Cybersecurity of Federal Networks and Critical Infrastructure*, May 11, 2017

[E.O. 14028](#), *Executive Order on Improving the Nation's Cybersecurity*, May 12, 2021

[E.O. 14144](#), *Strengthening and Promoting Innovation in the Nation's Cybersecurity*, January 16, 2025

[E.O. 14306](#), *Sustaining Select Efforts To Strengthen the Nation's Cybersecurity and Amending Executive Order 13694 and Executive Order 14144*, June 6, 2025

FISMA, [44 U.S.C. §§ 3551-3559](#)

NIST, [FIPS PUB 199](#), *Standards for Security Categorization of Federal Information and Information Systems*, February 2004, as amended

NIST, [FIPS PUB 200](#), *Minimum Security Requirements for Federal Information and Information Systems*, March 9, 2006, as amended

NIST, [NIST Cybersecurity Framework](#), website

NIST, [NISTIR 7693](#), *Specification for Asset Identification 1.1*, June 2011

NIST, [NIST Risk Management Framework](#), November 30, 2016, updated December 13, 2023, website

NIST, [SP 800-12](#), Revision 1, *An Introduction to Information Security*, June 2017

NIST, [SP 800-16, Volume 1](#), Revision 1, *Information Technology Security Training Requirements: A Role- and Performance-Based Model*, April 1998

NIST, [SP 800-18](#), Revision 1, *Guide for Developing Security Plans for Federal Information Systems*, February 2006, as amended

NIST, [SP 800-30](#), Revision 1, *Guide for Conducting Risk Assessments*, September 2012, as amended

NIST, [SP 800-34](#), Revision 1, *Contingency Planning Guide for Federal Information Systems*, May 2010, as amended

NIST, [SP 800-37](#), Revision 2, *Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy*, December 2018, as amended

NIST, [SP 800-39](#), *Managing Information Security Risk: Organization, Mission, and Information System View*, March 2011, as amended

NIST, [SP 800-47](#), Revision 1, *Managing the Security of Information Exchanges*, July 2021, as amended

NIST, [SP 800-53](#), Revision 5, *Security and Privacy Controls for Information Systems and Organizations*, September 2020,

NIST, [SP 800-60, Volume 1](#), Revision 1, *Guide for Mapping Types of Information and Information Systems to Security Categories*, August 2008, as amended

NIST, [SP 800-60, Volume 2](#), Revision 1, *Appendices to Guide for Mapping Types of Information and Information Systems to Security Categories*, August 2008, as amended

NIST, [SP 800-82](#), Revision 3, *Guide to Operational Technology (OT) Security*, September 28, 2023

NIST, [SP 800-137](#), *Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations*, September 2011, as amended

NIST, [SP 800-137A](#), *Assessing Information Security Continuous Monitoring (ISCM) Programs: Developing an ISCM Program Assessment*, May 21, 2020

NIST, [SP 800-160v1r1](#), *Engineering Trustworthy Secure Systems*, November 2022, as amended

NIST, [SP 800-160, Volume 2](#), Revision 1, *Developing Cyber-Resilient Systems: A Systems Security Engineering Approach*, December 2021

NIST, [SP 800-175B](#), Revision 1, *Guideline for Using Cryptographic Standards in the Federal Government: Cryptographic Mechanisms*, March 2020

NIST, [SP 800-213](#), *IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements*, November 2021

NIST, [SP 800-213a](#), *IoT Device Cybersecurity Guidance for the Federal Government: IoT Device Cybersecurity Requirement Catalog*, November 2021

OMB, A-123, *Management Accountability and Control*, found on the [Circulars](#) web page; updated by [M-16-17](#); modified by [M-17-26](#)

OMB, [A-130](#), *Managing Information as a Strategic Resource*, July 28, 2016

OMB, [M-02-01](#), *Guidance for Preparing and Submitting Security Plans of Action and Milestones*, October 17, 2001

OMB, [M-03-22](#), *OMB Guidance for Implementing the Privacy Provisions of the E-Government Act of 2002*, September 26, 2003

OMB, [M-16-17](#), *OMB Circular No. A-123, Management's Responsibility for Enterprise Risk Management and Internal Control*, July 15, 2016

OMB, [M-24-15](#), *Modernizing the Federal Risk and Authorization Management Program*, July 25, 2024

USDA, [DR 0100-001](#), *Departmental Directives System*, January 4, 2018, as amended

USDA, [DR 3105-001](#), *USDA Chief Information Officers Council*, October 23, 2024, as amended

USDA, [DR 3130-013](#), *Information Technology Capital Planning and Investment Control*, May 24, 2021, as amended

USDA, [DR 3185-001](#), *Enterprise Architecture*, April 19, 2022

USDA, [DR 3185-004](#), *Enterprise Zero Trust Architecture*, September 9, 2024

USDA, [DR 3520-002](#), *Configuration Management*, July 17, 2019

USDA, [DR 3505-003](#), *Access Control for Information and Information Systems*, July 17, 2019

USDA, [DR 3505-005](#), *Cybersecurity Incident Management*, November 30, 2018

USDA, [DR 3530-006](#), *Scanning and Remediation of Configuration and Patch Vulnerabilities*, June 5, 2019

USDA, [DR 3545-001](#), *Information Security Awareness (ISA) Program*, October 25, 2023

USDA, [DR 3650-001](#), *Cloud Computing*, May 24, 2023

USDA, [DR 4070-735-001](#), *Employee Responsibilities and Conduct*, October 4, 2007, as amended

USDA, [Information Security Continuous Monitoring Strategy Fiscal Years 2025–2028](#), September 2024

USDA, [Plan of Action & Milestones and Risk-Based Decisions Standard Operating Procedures](#), March 19, 2026

USDA, [Risk Management Framework Guide](#), June 10, 2025